

# Enhancing MySQL Security

---

Vinicius Grippa  
Percona



**PERCONA**  
**LIVE EUROPE**  
**FRANKFURT**

# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles



# Basic Principles

- Minimum access
- Isolate
- Audit
- Avoid spying
- Default firewall



# Agenda

- **SO/Cloud security**
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles



# OS/Cloud Security

---



# OS/Cloud security

- Uninstall services that are not used
- Do not run compilers
- Firewalls
- Block internet access
- Disable remote root login
- Use of SSH Key



# OS/Cloud security

- Use of Amazon Virtual Private Cloud (VPC)
- Use AWS Identity and Access Management (IAM) policies
- Use security groups



# Agenda

- OS/Cloud security
- **SSL**
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles





# SSL

---

# SSL

- Move information over a network in a secure fashion
- SSL provides an way to cryptograph the data
- Default for MySQL 5.7 or higher
- Certificates
  - MySQL 5.7
    - *mysql\_ssl\_rsa\_setup*
  - MySQL 5.6
    - *openssl*



# SSL

```
mysql > show global variables like '%ssl%';
```

```
+-----+-----+
| Variable_name | Value          |
+-----+-----+
| have_openssl  | YES           |
| have_ssl      | YES           |
| ssl_ca        | ca.pem        |
| ssl_capath    |                |
| ssl_cert      | server-cert.pem |
| ssl_cipher    |                |
| ssl_crl       |                |
| ssl_crlpath   |                |
| ssl_key       | server-key.pem |
+-----+-----+
```

```
9 rows in set (0.03 sec)
```

```
mysql: root@localhost ((none)) GRANT ALL PRIVILEGES ON *.* TO
'ssluser'@'%' IDENTIFIED BY 'sekret' REQUIRE SSL;
```

```
Query OK, 0 rows affected, 1 warning (0.00 sec) Query OK, 0 rows affected
(0.01 sec)
```

```
[root@node1 ~]# mysql -ussluser -psekret
--ssl-cert=/var/lib/mysql/client-cert.pem
--ssl-key=/var/lib/mysql/client-key.pem --ssl-ca=/var/lib/mysql/ca.pem -h
127.0.0.1 -P 3306 -e "\s"| grep SSL
```

```
mysql: [Warning] Using a password on the command line interface can be
insecure.
```

```
SSL:                Cipher in use is ECDHE-RSA-AES128-GCM-SHA256
```

# SSL - Cons

- Performance drop
  - <https://www.percona.com/blog/2013/10/10/mysql-ssl-performance-overhead/>

# Agenda

- OS/Cloud security
- SSL
- **Password management**
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles



# Password Management

---

# Password Management

- Password expiration
- `validate_password` plugin



# Password expiration

- MySQL enables database administrators to expire account passwords manually, and to establish a policy for automatic password expiration. Expiration policy can be established globally, and individual accounts can be set to either defer to the global policy or override the global policy with specific per-account behavior.



# Password expiration

## Individual accounts

```
mysql> create user test_expired_user@localhost identified by 'Sekr$K1et'  
PASSWORD EXPIRE INTERVAL 1 day;
```

Query OK, 0 rows affected (0.01 sec)

## Globally

```
mysql> SET GLOBAL default_password_lifetime = 1;
```



# validate\_plugin

Its main purpose is to test passwords and improve security. It is possible to ensure the strenght, lenght and required characters of the password



# validate\_plugin - Installing

## # Runtime

```
mysql: root@localhost ((none)) > INSTALL PLUGIN validate_password  
SONAME 'validate_password.so';
```

```
Query OK, 0 rows affected (0.07 sec)
```

## # my.cnf

```
[mysqld]
```

```
plugin-load-add=validate_password.so
```



# validate\_plugin - Validate

```
mysql: root@localhost ((none)) > show global variables like '%plugin%';
```

| Variable_name                 | Value                    |
|-------------------------------|--------------------------|
| default_authentication_plugin | mysql_native_password    |
| plugin_dir                    | /usr/lib64/mysql/plugin/ |

2 rows in set (0.00 sec)

```
mysql: root@localhost ((none)) > SELECT PLUGIN_NAME, PLUGIN_STATUS  
FROM INFORMATION_SCHEMA.PLUGINS  
WHERE PLUGIN_NAME LIKE 'validate%';
```

| PLUGIN_NAME       | PLUGIN_STATUS |
|-------------------|---------------|
| validate_password | ACTIVE        |

1 row in set (0.00 sec)



# validate\_plugin - Example

```
mysql: root@localhost ((none)) > set global validate_password_length = 6;  
Query OK, 0 rows affected (0.00 sec)
```

```
mysql: root@localhost ((none)) > set global validate_password_policy=2;  
Query OK, 0 rows affected (0.00 sec)
```

```
mysql: root@localhost ((none)) > create user test_password@localhost identified by  
'PasSw0Rd';  
ERROR 1819 (HY000): Your password does not satisfy the current policy requirements
```

```
mysql: root@localhost ((none)) > create user test_password@localhost identified by  
'PasSw0Rd12@';  
Query OK, 0 rows affected (0.00 sec)
```



# Agenda

- OS/Cloud security
- SSL
- Password management
- **Audit plugin**
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles



# Audit Plugin

---



# Audit Plugin

- MySQL Enterprise – Paid
- Percona Server (works with community version) – Free
- Its different from general log
- Filter by command / user / database





# Audit Plugin - Installing

```
Mysql > INSTALL PLUGIN audit_log SONAME 'audit_log.so';  
Query OK, 0 rows affected (0.05 sec)
```

```
Mysql > SELECT PLUGIN_NAME, PLUGIN_STATUS FROM  
INFORMATION_SCHEMA.PLUGINS WHERE PLUGIN_NAME LIKE  
'audit%';
```

```
+-----+-----+  
| PLUGIN_NAME | PLUGIN_STATUS |  
+-----+-----+  
| audit_log   | ACTIVE        |  
+-----+-----+  
1 row in set (0.00 sec)
```

# Audit Plugin

```
[mysqld]  
## Audit Logging ##  
audit_log_policy=ALL  
audit_log_format=JSON  
audit_log_file=/var/log/mysql/audit.log  
audit_log_rotate_on_size=1024M  
audit_log_rotations=10
```



# Audit Plugin

```
mysql: root@localhost ((none)) > show global variables like 'audit%';
```

| +-----+-----+               |                          |
|-----------------------------|--------------------------|
| Variable_name               | Value                    |
| +-----+-----+               |                          |
| audit_log_buffer_size       | 1048576                  |
| audit_log_exclude_accounts  |                          |
| audit_log_exclude_commands  |                          |
| audit_log_exclude_databases |                          |
| audit_log_file              | /var/log/mysql/audit.log |
| audit_log_flush             | OFF                      |
| audit_log_format            | JSON                     |
| audit_log_handler           | FILE                     |
| audit_log_include_accounts  |                          |
| audit_log_include_commands  |                          |
| audit_log_include_databases |                          |
| audit_log_policy            | ALL                      |
| audit_log_rotate_on_size    | 1073741824               |
| audit_log_rotations         | 10                       |
| audit_log_strategy          | ASYNCHRONOUS             |
| audit_log_syslog_facility   | LOG_USER                 |
| audit_log_syslog_ident      | percona-audit            |
| audit_log_syslog_priority   | LOG_INFO                 |
| +-----+-----+               |                          |

```
18 rows in set (0.02 sec)
```

# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- **Percona Server encryption features**
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles



# Percona Server encryption features

---



# Percona Server encryption

- Percona server provide extra encryption
- encrypt\_binlog
- encrypt\_tmp\_files
- innodb\_encrypt\_online\_alter\_logs
- innodb\_encrypt\_tables – BETA quality
- innodb\_parallel\_dblwr\_encrypt – ALPHA quality
- innodb\_sys\_tablespace\_encrypt – ALPHA quality
- innodb\_temp\_tablespace\_encrypt – BETA quality



# Percona Server encryption

```
[mysqld]  
# Binary Log Encryption  
encrypt_binlog  
master_verify_checksum = 1  
binlog_checksum = 1
```

```
mysql: root@localhost ((none)) > show global variables like  
'%encrypt_binlog%';
```

```
+-----+-----+  
| Variable_name | Value |  
+-----+-----+  
| encrypt_binlog | ON    |  
+-----+-----+
```

```
1 row in set (0.00 sec)
```

# Percona Server encryption

```
mysql: root@localhost ((none)) > show global variables like '%encrypt%';
```

| +-----+-----+                    |             |
|----------------------------------|-------------|
| Variable_name                    | Value       |
| +-----+-----+                    |             |
| block_encryption_mode            | aes-128-ecb |
| encrypt_binlog                   | ON          |
| encrypt_tmp_files                | OFF         |
| innodb_encrypt_online_alter_logs | OFF         |
| innodb_encrypt_tables            | OFF         |
| innodb_parallel_dblwr_encrypt    | OFF         |
| innodb_sys_tablespace_encrypt    | OFF         |
| innodb_temp_tablespace_encrypt   | OFF         |
| +-----+-----+                    |             |

```
8 rows in set (0.00 sec)
```



# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- **MySQL 8 features (undo, redo encryption)**
- TDE
- New caching\_sha2\_password
- FIPS mode
- Roles



# MySQL 8 features (undo, redo encryption)

---



# MySQL 8 - (undo, redo encryption)

- MySQL 8 extends tablespace encryption feature to redo log and undo log
- It is necessary using one of the Keyring plugins

# MySQL 8 - (undo, redo encryption)

- The process is very straightforward, to enable the encryption on the redo log and the undo log:

```
mysql> set global innodb_undo_log_encrypt = 1;  
Query OK, 0 rows affected (0.00 sec)
```

```
mysql> set global innodb_redo_log_encrypt = 1;  
Query OK, 0 rows affected (0.00 sec)
```

```
mysql> show global variables like '%log_encrypt%';
```

| Variable_name           | Value |
|-------------------------|-------|
| innodb_redo_log_encrypt | ON    |
| innodb_undo_log_encrypt | ON    |

```
2 rows in set (0.00 sec)
```

# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- **TDE**
- New caching\_sha2\_password
- FIPS mode
- Roles



# Transparent Data Encryption(TDE)

---

# Transparent Data Encryption (TDE)

- Enables data-at-rest encryption in the database
- Encryption and decryption occurs without any additional coding, data type or schema modifications

# Transparent Data Encryption (TDE)

```
[mysqld]  
# TDE  
early-plugin-load=keyring_file.so  
keyring-file-data=/var/lib/mysql-keyring/keyring
```

```
mysql: root@localhost ((none)) > INSTALL PLUGIN keyring_udf SONAME 'keyring_udf.so';  
Query OK, 0 rows affected (0.00 sec)
```

```
mysql: root@localhost ((none)) > SELECT PLUGIN_NAME, PLUGIN_STATUS  
      FROM INFORMATION_SCHEMA.PLUGINS  
      WHERE PLUGIN_NAME LIKE 'keyring%';
```

```
+-----+-----+  
| PLUGIN_NAME | PLUGIN_STATUS |  
+-----+-----+  
| keyring_file | ACTIVE      |  
| keyring_udf  | ACTIVE      |  
+-----+-----+
```



# Transparent Data Encryption (TDE)

```
mysql: root@localhost ((none)) > SELECT keyring_key_generate('MyKey', 'AES', 32);
```

```
+-----+  
| keyring_key_generate('MyKey', 'AES', 32) |  
+-----+  
|                               1 |  
+-----+
```

```
1 row in set (0.00 sec)
```

```
mysql> CREATE TABLESPACE `amer_meeting1` ADD DATAFILE 'amer_meeting1.ibd' ENCRYPTION = 'Y'  
Engine=InnoDB;
```

```
Query OK, 0 rows affected (0.01 sec)
```

```
mysql: root@localhost (test) > CREATE TABLE t1 (a INT, b TEXT) TABLESPACE vgrippa  
ENCRYPTION='N';
```

```
ERROR 1478 (HY000): InnoDB: Tablespace `vgrippa` can contain only an ENCRYPTED tables.
```

```
mysql: root@localhost (test) > CREATE TABLE t1 (a INT, b TEXT) TABLESPACE vgrippa  
ENCRYPTION='Y';
```

```
Query OK, 0 rows affected (0.02 sec)
```

# Transparent Data Encryption (TDE)

- A flag field in the INFORMATION\_SCHEMA.INNODB\_SYS\_TABLESPACES has bit number 13 set if tablespace is encrypted.

```
mysql: root@localhost (test) > SELECT space, name, flag, (flag & 8192) != 0  
AS encrypted FROM  
INFORMATION_SCHEMA.INNODB_SYS_TABLESPACES WHERE name in  
( 'vgrippa' );
```

```
+-----+-----+-----+-----+  
| space | name   | flag | encrypted |  
+-----+-----+-----+-----+  
|  156 | vgrippa | 10240 |      1 |  
+-----+-----+-----+-----+  
1 row in set (0.00 sec)
```

# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- **New caching\_sha2\_password**
- FIPS mode
- Roles



caching\_sha2\_password

---

# cached\_sha2\_password

MySQL provides two authentication plugins that implement SHA-256 hashing for user account passwords:

- sha256\_password: Implements basic SHA-256 authentication.
- cached\_sha2\_password: Implements SHA-256 authentication (like sha256\_password), but uses caching on the server side for better performance and has additional features for wider applicability. (In MySQL 5.7, cached\_sha2\_password is implemented only on the client)

**Note:** In MySQL 8.0, cached\_sha2\_password is the default authentication plugin rather than mysql\_native\_password.

# Example

```
# MySQL 8
[mysqld]
default_authentication_plugin=caching_sha2_password
```

```
mysql> CREATE USER 'sha2user'@'localhost'
IDENTIFIED WITH caching_sha2_password BY 'password';
```

Query OK, 0 rows affected (0.06 sec)

```
mysql> select user,host, plugin from mysql.user where user like 'sha2user%';
```

|          |           |                       |
|----------|-----------|-----------------------|
| user     | host      | plugin                |
| sha2user | localhost | caching_sha2_password |

1 row in set (0.00 sec)

# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- **FIPS mode**
- Roles



# FIPS mode

---



# FIPS

- MySQL supports FIPS mode, if compiled using OpenSSL, and an OpenSSL library and FIPS Object Module are available at runtime.
- FIPS mode on the server side applies to cryptographic operations performed by the server. This includes replication (master/slave and Group Replication) and X Plugin, which run within the server. FIPS mode also applies to attempts by clients to connect to the server.



# Example

```
mysql> show global variables like '%fips%';
```

```
+-----+-----+  
| Variable_name | Value |  
+-----+-----+  
| ssl_fips_mode | ON    |
```

```
+-----+-----+  
1 row in set (0.01 sec)
```

```
mysql> set global ssl_fips_mode=1;  
Query OK, 0 rows affected (0.06 sec)
```

```
mysql> select md5('a');
```

```
+-----+  
| md5('a') |  
+-----+  
| 00000000000000000000000000000000 |
```

```
+-----+  
1 row in set, 1 warning (0.00 sec)
```



# Example

```
mysql> show warnings;
```

```
+-----+-----+-----+
| Level | Code | Message                                     |
+-----+-----+-----+
| Warning | 11272 | SSL fips mode error: FIPS mode ON/STRICT: MD5 digest is not supported. |
+-----+-----+-----+
```

```
1 row in set (0.00 sec)
```

```
mysql> select sha2('a', 256);
```

```
+-----+
| sha2('a', 256) |
+-----+
| ca978112ca1bbdcaf231b39a23dc4da786eff8147c4e72b9807785afee48bb |
+-----+
```

```
1 row in set (0.00 sec)
```



# Agenda

- OS/Cloud security
- SSL
- Password management
- Audit plugin
- Percona Server encryption features
- MySQL 8 features (undo, redo encryption)
- TDE
- New caching\_sha2\_password
- FIPS mode
- **Roles**



# Roles

---

# Roles

- MySQL 8 comes with Roles feature. A role is a named collection of privileges. Like user accounts, roles can have privileges granted to and revoked from them.

# Roles

Example

```
mysql> create role app_read;  
Query OK, 0 rows affected (0.03 sec)
```

```
mysql> grant select on *.* to app_read;  
Query OK, 0 rows affected (0.04 sec)
```

```
mysql> select * from app_db.joinit;  
ERROR 1142 (42000): SELECT command denied to user 'test_role'@'localhost' for table 'joinit'
```

```
mysql> SELECT CURRENT_ROLE();
```

```
+-----+  
| CURRENT_ROLE() |  
+-----+  
| NONE          |  
+-----+  
1 row in set (0.00 sec)
```

```
mysql> SET ROLE all;  
Query OK, 0 rows affected (0.00 sec)
```

```
mysql> SELECT CURRENT_ROLE();
```

```
+-----+  
| CURRENT_ROLE() |  
+-----+  
| 'app_read'@'%' |  
+-----+  
1 row in set (0.00 sec)
```

```
mysql> select * from app_db.joinit;
```

# References

## # SO/Cloud Security

<https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/UsingWithRDS.html>

[https://docs.aws.amazon.com/vpc/latest/userguide/VPC\\_SecurityGroups.html](https://docs.aws.amazon.com/vpc/latest/userguide/VPC_SecurityGroups.html)

## # Audit log

<https://www.percona.com/blog/2015/09/10/percona-server-audit-log-plugin-best-practices/>

## # caching\_sha2\_password

<https://dev.mysql.com/doc/refman/5.7/en/caching-sha2-pluggable-authentication.html>

## # SSL

<https://www.percona.com/blog/2013/06/22/setting-up-mysql-ssl-and-secure-connections/#setup>

<https://www.percona.com/blog/2013/10/10/mysql-ssl-performance-overhead/>

## # TDE

[https://www.percona.com/doc/percona-server/LATEST/management/data\\_at\\_rest\\_encryption.html](https://www.percona.com/doc/percona-server/LATEST/management/data_at_rest_encryption.html)

[https://www.percona.com/doc/percona-server/LATEST/management/data\\_at\\_rest\\_encryption.html#usage](https://www.percona.com/doc/percona-server/LATEST/management/data_at_rest_encryption.html#usage)

<https://dev.mysql.com/doc/refman/5.7/en/keyring-file-plugin.html>

## # Roles

[https://dev.mysql.com/doc/refman/8.0/en/server-system-variables.html#sysvar\\_activate\\_all\\_roles\\_on\\_login](https://dev.mysql.com/doc/refman/8.0/en/server-system-variables.html#sysvar_activate_all_roles_on_login)

<https://dev.mysql.com/doc/refman/8.0/en/roles.html>

## # Password management

<https://dev.mysql.com/doc/refman/5.7/en/password-management.html>

<https://dev.mysql.com/doc/refman/5.7/en/validate-password-installation.html>

<https://dev.mysql.com/doc/refman/5.7/en/validate-password-options-variables.html>

## # FIPS

<https://dev.mysql.com/doc/refman/8.0/en/fips-mode.html>

## # Percona Server 8.0 Alpha release

<https://www.percona.com/blog/2018/09/27/announcement-alpha-build-of-percona-server-8-0/>

## # MySQL 8 Redo and Undo encryption

<https://dev.mysql.com/doc/refman/8.0/en/innodb-tablespace-encryption.html#innodb-tablespace-encryption-about>

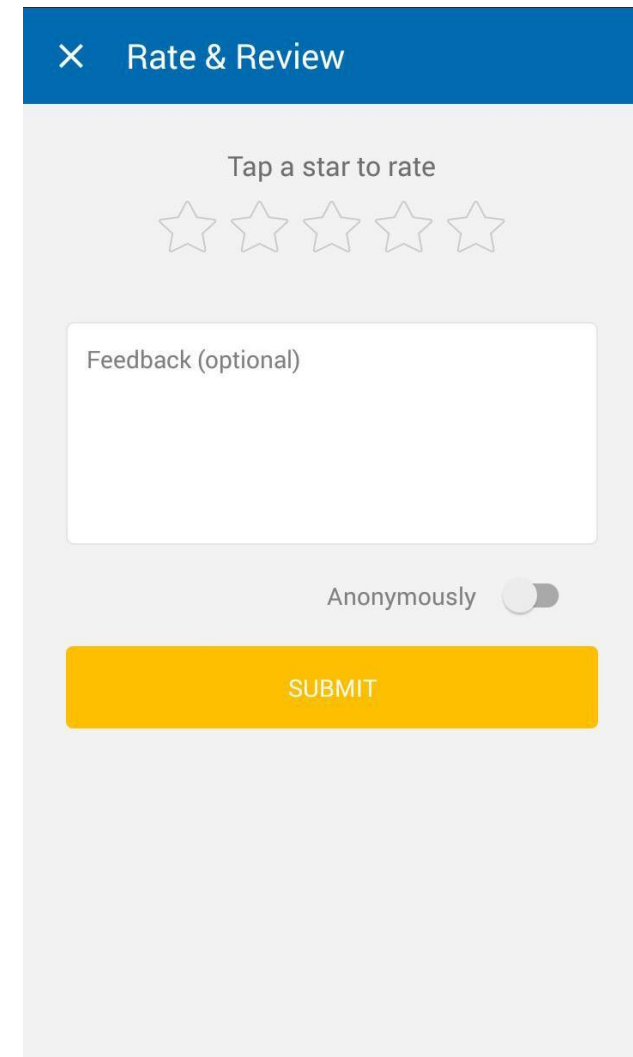
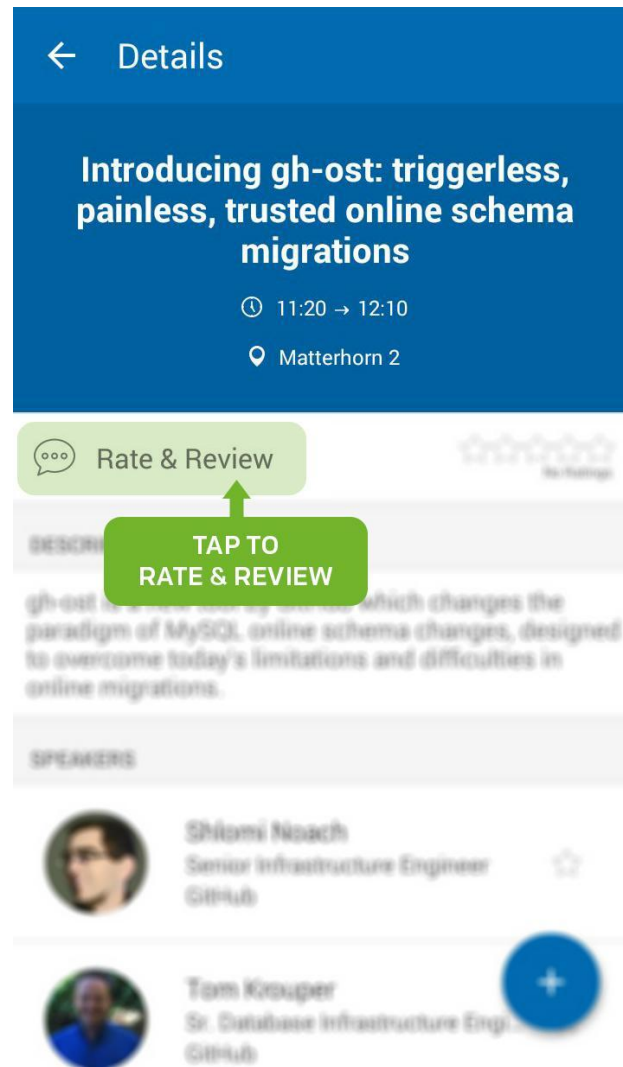
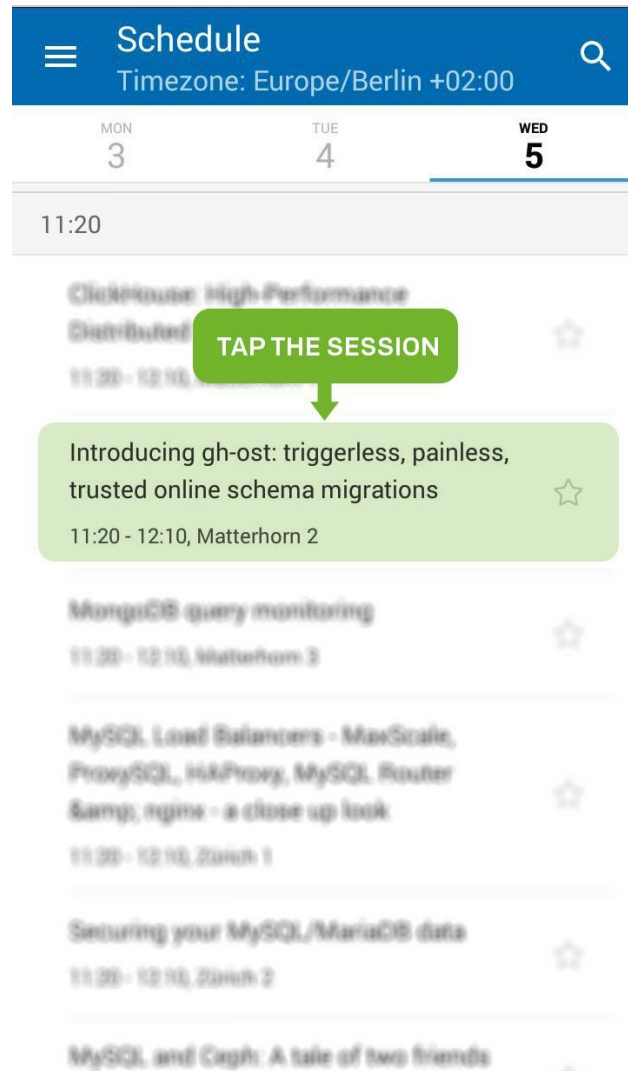


# Questions?

---

Click to add text

# Rate My Session



# Thank You Sponsors!!

facebook



OlinData 



Shannon Systems



severalnines



IDEA



database  
TRENDS AND APPLICATIONS

Packt>

ODBMS.org

